2026 SHENZHEN FINTECHATHON · INTERNATIONAL TRACK · TOPIC C

TuitionPilot

An AI agent that helps Indian families pay university fees abroad: it checks the invoice is genuine, explains every rupee, and pays only after the parent's own device signs the exact plan.

1. **Signed invoices instead of payee lists**
2. **The parent's device signs every payment**
3. **Every number traced to a rule and source**

Chandan · Nishanth | Synthetic data only · Sandbox bank, no real money · Not tax advice · Not RBI-approved

Paying fees abroad: four hard questions, one big fraud risk

1

How much of the yearly LRS limit is left?

USD 250,000 per person per year, all purposes together (rule still unverified)

2

How much TCS tax will the bank add?

2% above Rs 10 lakh if self-funded; 0% with an education loan

3

Which route is really cheapest?

A low fee can hide a worse exchange rate; the markup is never shown as a fee

4

Which papers does the bank want?

A2 form, PAN, invoice, admission letter, passport, visa document

THE FRAUD

“Our bank details have changed. Please pay within 24 hours.”

A classic way to steal tuition fees. In TuitionPilot this attack fails by design: the university’s signature covers its bank account.

Rates come from our versioned rule pack; rules not yet checked against RBI and Income Tax sources are flagged (slide 10).

One guided flow, from invoice to receipt

1

Welcome

Two consents before any data is read

2

Invoice

Animated check of the university's signature chain

3

Questions

One at a time; the agent asks, never guesses

4

Best route

Cost chart, what-if sliders, LRS limit gauge

5

Review & sign

PIN pad; the parent's device signs the plan

6

Receipt

Transaction, certificate, signature, audit entry

Agent, live panel

Every step and policy decision as it happens, the rule trace with sources, exactly what the AI saw (masked), and the audit chain.

Attack lab

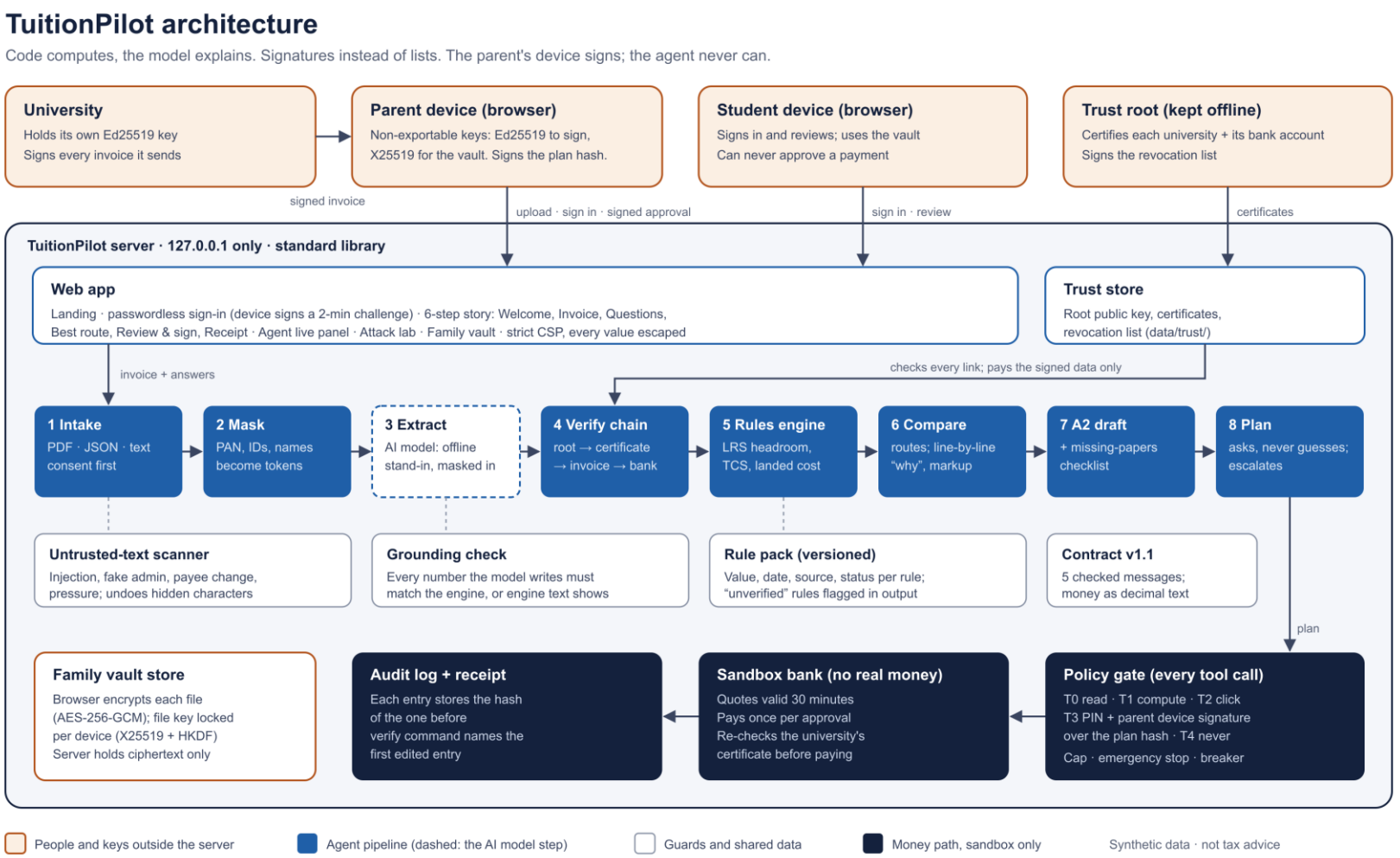
Runs 16 attacks against a separate copy of the agent and shows which defence stopped each one.

Family devices and vault

Passwordless sign-in on each enrolled device. Documents are encrypted in the browser; a student can review but never sign.

Code computes; the AI explains. Tax, cost and limits come from tested code. The AI only reads the invoice and words results, sees masked text only, and today is an offline stand-in.

Architecture: keys with people, money in the sandbox



Orange: outside the server

University, parent and student devices, trust root. Every private key lives here.

Blue: agent pipeline

Intake to plan in 8 steps. The dashed step is the only AI step; it sees masked text.

Navy: money path

Policy gate → sandbox bank → hash-chained audit log and receipt.

India’s LRS and TCS rules, turned into tested code

Rule	Value in the rule pack	Status
LRS yearly cap	USD 250,000 per person, April–March	**Unverified**
TCS threshold	Rs 10 lakh per PAN per year, all purposes	Secondary source
Education, self-funded	2% above the threshold (from 1 Apr 2026)	Secondary source
Education, loan-funded	0% (loan from a notified institution)	Secondary source
No PAN	5% above the threshold	**Unverified**

TCS = rate × (this year’s total − the larger of earlier payments or Rs 10 lakh)
Never below zero. Every result carries the rule id, pack version, effective date and source. The engine refuses dates before a rule took effect, and unverified rules are flagged in every output.

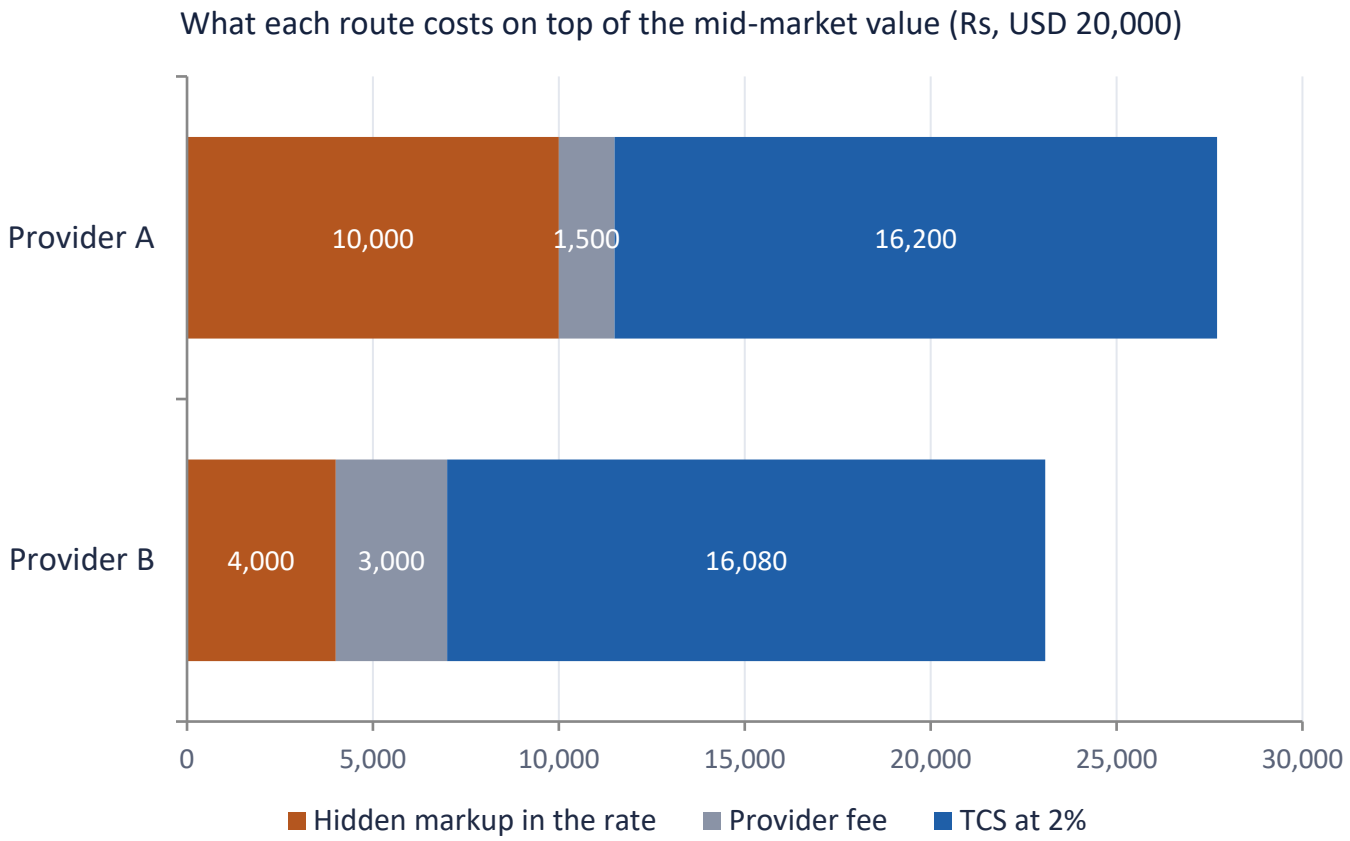
Worked example (scenario A2)

Self-funded Rs 15 lakh, no earlier payments

This year’s total	Rs 15,00,000
Minus the threshold	− Rs 10,00,000
Taxable part	Rs 5,00,000
TCS at 2%	**Rs 10,000**

With an education loan instead (A3): TCS is Rs 0.

Route comparison: the lowest fee is not the cheapest



Why Provider B wins, line by line

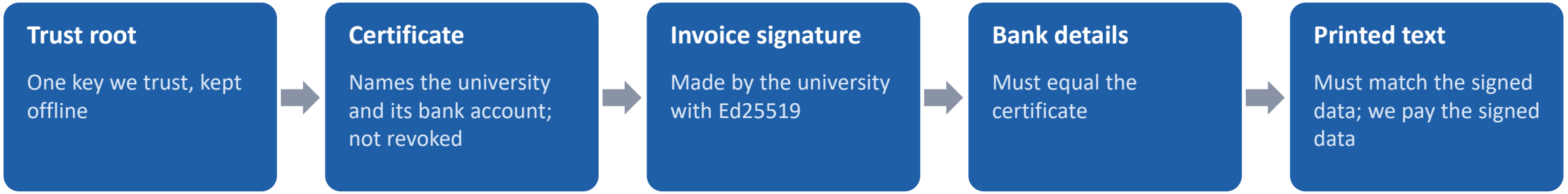
Better rate (90.20 vs 90.50)	+ Rs 6,000
Higher provider fee	– Rs 1,500
Less TCS (less rupees sent)	+ Rs 120
Saving with B	**Rs 4,620**

Totals: B Rs 18,23,080 vs A Rs 18,27,700. Code writes every line, and the lines add up exactly to the saving.

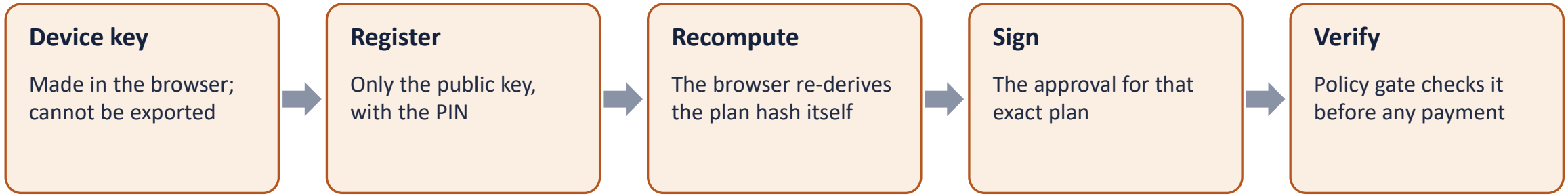
Scenario A8, engine output. Mid-market rate 90.00 is the example value from our tests, not a live rate. No GST or correspondent charges in this example.

Security: signatures instead of payee lists

University invoice. A changed bank account breaks the signature.



Parent approval. The agent never holds the parent's key, so it cannot forge an approval or change the plan.



Ed25519 written in plain Python following RFC 8032, nothing to install; checked against the RFC test vectors and a signature made by the browser's WebCrypto.

Defence in depth: each layer assumes the one before can fail

Tier	What the agent may do	Approval
T0	Read the invoice, check signatures	None
T1	Compute and draft	None
T2	Save or share drafts	A click
T3	Sandbox payment to a signature-verified payee	**PIN + parent device signature over the plan hash**
T4	New or unverified payee, change limits, skip approval	**Never**

The AI model has no payment tool. Every tool call passes the policy gate. Sign-in is passwordless: the device signs a one-time 2-minute challenge, and a new device needs a parent device's signature.

Masking

PAN, Aadhaar, passport, account, phone and names become tokens before the AI sees text

Grounding check

Every number the AI writes must match the engine, or the engine's text is shown

Text scanner

Flags injection, fake admin, payee change and pressure, even when disguised

Breaker + emergency stop

Per-payment cap; 3 denied money actions freeze the agent until a PIN reset

Hash-chained audit log

Each entry stores the hash of the one before; edits are detected

Encrypted family vault

AES-256-GCM in the browser; keys locked per device (X25519); server sees ciphertext

Evidence: run it yourself, one command each

227

tests pass

27 / 27

scenarios pass

16 / 16

attacks stopped in the attack lab

153

audit entries; the hash chain verifies

Scenarios by group

A Task completion	**10 / 10 pass**
B Safe execution	**6 / 6 pass**
C Attacks, incl. forged approval and revoked key	**9 / 9 pass**
D Privacy	**2 / 2 pass**

Finance audit: 400 random cases

The engine matched an independent formula in every case. The audit found 3 agent bugs, all fixed with tests:

- an earlier in-app payment was not counted
- inconsistent USD answers were accepted
- no PAN + loan applied 0% silently (now a warning)

```
python -m unittest discover -s tests -t .   ·   python -m scenarios.runner   ·   python -m app.demo_run
```

Honest limits, and what comes next

Tax rules not yet verified

- Unverified: LRS cap USD 250,000; no-PAN rate 5%; earlier payments counting toward Rs 10 lakh; TCS on the amount sent, not fees
- Secondary sources: the Rs 10 lakh threshold, 2% and 0% education rates
- Not modelled: GST on the currency conversion itself

Prototype limits

- The AI step is an offline, deterministic stand-in
- Ed25519 code is not hardened (not constant-time, not audited)
- Demo keys are synthetic; one trust root
- Local server: no Origin check yet; demo PIN is fixed

Next steps

- Check every rule against the RBI Master Direction and the Income-tax Act 2025 s.394
- Connect a hosted AI model behind masking, grounding and the policy gate
- Vetted crypto library or hardware keys; offline parent recovery key
- Same-origin checks and cookie sessions on the server

Synthetic data only · Sandbox bank, no real money · Drafts, not official RBI or bank forms · Not tax advice